



ELISAR: A Multi-Agent cybersecurity framework integrating retrieval-augmented generation for Blue, Red, and GRC operations

Sabri Allani¹ · Karam Bou-Chaaya¹ · Helmi Rais¹

Received: 10 March 2025 / Revised: 20 November 2025 / Accepted: 28 November 2025

© The Author(s), under exclusive licence to Springer Science+Business Media, LLC, part of Springer Nature 2025

Abstract

A cybersecurity framework, ELISAR, has been developed to address the evolving challenges of modern cybersecurity operations, including governance, risk management, and threat mitigation. Unlike conventional AI-driven models, ELISAR is designed as a collaborative multi-agent system, in which specialized agents are deployed to operate autonomously while interacting within a modular and scalable architecture. Multiple domain-specific agents are orchestrated by the ELISAR Engine, with each agent being optimized for distinct cybersecurity tasks. For instance, ELISAR for GRC (Governance, Risk, and Compliance) is supported by a vector-based knowledge retrieval mechanism trained on regulatory standards such as NIS2, ISO 27001, and ISO 42001, enabling compliance-driven decision-making. For penetration testing, a RAG enhanced knowledge base is utilized, curated from security assessment datasets to support proactive vulnerability exploration. The defensive suite, Blue ELISAR, is composed of intelligent sub-agents, including ELISAR Honeypots for deception, ELISAR Next-Gen Firewall for real-time detection, and ELISAR Smart DLP for adaptive data protection. Through the integration of autonomous reasoning, contextual knowledge retrieval, and real-time adaptability, ELISAR is presented as an interpretable and domain-specialized cybersecurity assistant, in contrast to monolithic LLM-based solutions. This extended version of the manuscript includes additional system design details, formal modeling, and an expanded experimental evaluation across defensive, offensive, and compliance cybersecurity domains. Improvements in accuracy, context relevance, and result stability are observed when agentic AI is combined with retrieval-based methods, while latency remains comparable across tasks.

Keywords Cybersecurity · Large Language Models · Generative AI · Agentic AI · Risk Assessment · Governance · Threat Mitigation

✉ Sabri Allani
sabri.allani@expleogroup.com; sabri.allani@gmail.com

Karam Bou-Chaaya
karam.bou-chaaya@expleogroup.com; karam.bc@gmail.com

Helmi Rais
helmi.rais@expleogroup.com

¹ Expleo Group, Cybersecurity R&D Department, Montigny-le-Bretonneux, France

1 Introduction

Cybersecurity threats are evolving at an unprecedented pace, necessitating advanced AI-driven solutions that can adapt dynamically to emerging risks. Traditional cybersecurity frameworks rely heavily on static rule-based systems or monolithic AI models, which often struggle with scalability, explainability, and adaptability [8, 20, 21, 23].

This article is an extended version of a prior publication presented at the International Conference on Management of Digital EcoSystems (MEDES 2025) [2]. While the original version introduced the foundational concepts of ELISAR, this extended manuscript presents an agentic architecture based on the collaboration of specialized AI agents and the integration of Retrieval-Augmented Generation (RAG). It further expands the system design, provides formal mathematical modeling, and includes a broader experimental evaluation across defensive, offensive, and compliance cybersecurity domains.

To address these challenges, a cybersecurity framework called ELISAR has been introduced. This framework leverages both Agentic AI and Retrieval-Augmented Generation (RAG) to enable intelligent collaboration between autonomous agents across cybersecurity domains. Unlike traditional LLM-based solutions, ELISAR employs a multi-agent architecture, where domain-specific AI agents operate autonomously yet collaboratively to enhance cybersecurity intelligence. Each specialized agent within ELISAR is designed to perform distinct security tasks, ensuring a modular and scalable system that effectively integrates real-time adaptability with compliance-driven decision-making.

At the core of ELISAR lies a RAG-powered knowledge retrieval system, which dynamically integrates external regulatory knowledge bases and historical security data to optimize risk assessment. ELISAR's agents include:

- **Blue ELISAR:** Defensive security intelligence, incorporating AI-driven honeypots, next-generation firewalls, and adaptive data loss prevention (DLP).
- **Red ELISAR:** Offensive security and penetration testing, leveraging RAG-enhanced pentest databases for proactive security assessments.
- **GRC ELISAR:** Governance, risk, and compliance assessment, utilizing a vector-based retrieval system to align security measures with NIS2, ISO 27001, ISO 42001, and the EU AI Act [1].

Through its Agentic AI approach, ELISAR surpasses conventional generative AI models by integrating autonomous reasoning, knowledge retrieval, and real-time adaptability into cybersecurity operations. This novel framework ensures a more interpretable, scalable, and privacy-preserving cybersecurity solution compared to monolithic LLM-based copilots.

The ELISAR architecture has also been aligned with the Secure AI Framework (SAIF) [9] and NIST recommendations [16], ensuring trustworthiness, explainability, and regulatory readiness. Its multi-agent orchestration reduces single points of failure, increases domain specificity, and improves responsiveness to adversarial behavior and evolving legal mandates.

The remainder of this paper is organized as follows: Section 2 provides an overview of existing AI-driven cybersecurity solutions and highlights their limitations. Section 3 presents the architectural components and innovations of ELISAR. Section 4 describes the

empirical evaluation of ELISAR's performance across multiple cybersecurity domains. Section 5 concludes the paper and discusses future research directions.

2 Related work

Cybersecurity has witnessed significant advances with the integration of artificial intelligence (AI), especially in the domains of risk assessment, threat modeling, and regulatory compliance. This section reviews previous work in four key areas: AI-driven cybersecurity, Retrieval-Augmented Generation (RAG), multi-agent approaches, and compliance and governance. A comparative analysis is also presented to position the ELISAR framework within this landscape.

2.1 AI-Driven cybersecurity risk assessment

The detection, analysis, and mitigation of cyber threats have been extensively explored through AI techniques. In the *Cost of a Data Breach Report* by Ponemon Institute [10], the economic impact of cybersecurity breaches was quantified, emphasizing the critical need for automated risk assessment. Additionally, the report identified significant limitations arising from manual review processes in threat-intelligence workflows, reinforcing the advantages of AI-based document analysis and automated processing.

More specifically, Ferrag et al. [8] summarized how generative AI and large language models (LLMs) can enhance threat detection. However, these approaches remain constrained by static deployment models, limiting real-time adaptability. Smith and Doe [20] offered a systematic review on LLM applications in cybersecurity, highlighting both their promise and their challenges in dynamic operational settings. Localized LLMs such as Mistral [14] and Ollama [17] have been proposed for industrial scenarios, yet these models often lack retrieval capabilities and agentic collaboration.

2.2 Retrieval-augmented generation in cybersecurity

Retrieval-Augmented Generation (RAG) has been proposed to overcome limitations of purely generative AI by integrating external knowledge retrieval into the generation process. Vector-based systems such as Pinecone [19], Faiss [7], Weaviate [22], and Elasticsearch [5] have been employed to support semantic similarity search, enabling enhanced matching of threat signatures and identification of relevant cybersecurity artifacts.

However, most RAG implementations operate as single-agent pipelines, typically lacking distributed reasoning or specialization across security domains. These approaches often remain limited in adaptability and cannot handle the heterogeneity of cybersecurity knowledge bases. Furthermore, the retrieval layer is frequently disconnected from real-time operational intelligence or compliance requirements.

Recent developments have introduced more advanced RAG-based architectures. For example, ARCeR [12] proposed an agentic RAG system capable of automatically generating and deploying cyber ranges from natural language inputs, outperforming traditional static retrieval frameworks. Similarly, RAGENTIC [13] demonstrated a multi-agent RAG-

enhanced orchestration where a master agent coordinates specialized sub-agents through secure vector retrieval and real-time embedding workflows.

In contrast to existing mono-agent designs, the proposed ELISAR framework integrates RAG modules across three domain-specialized agents—Blue, Red, and GRC—thereby enhancing real-time retrieval precision and context adaptation within defense, offense, and governance tasks. This distributed RAG deployment improves response accuracy, minimizes cognitive overload in large language models, and supports compliance-aware decision-making.

2.3 Multi-agent architectures and agentic AI

The use of multi-agent systems has been investigated to distribute cybersecurity tasks across autonomous units. In particular, MITRE ATT&CK for AI [15] introduced conceptual taxonomies describing adversarial behaviours, although practical implementations of collaborative agentic models were not detailed. Autonomous offensive agents leveraging generative models were explored in [21], yet no mechanisms for defensive coordination or regulatory alignment were provided. Similarly, ENISA guidelines [6] advocated the adoption of layered architectures in AI cybersecurity, but these remained at a theoretical level without operational instantiation.

Recent advances have led to the emergence of several operational frameworks. ARCeR [12] introduced an agentic RAG system capable of automatically generating and deploying cyber ranges from natural language specifications, significantly improving over classical retrieval-based tools. MAESTRO [3], proposed by the Cloud Security Alliance, presented a threat modeling framework tailored to the risks posed by agentic AI systems, offering a layered abstraction for security engineering. RAGENTIC [13], developed by Microsoft, implemented a modular orchestration scheme in which a master agent coordinates a network of RAG-enhanced agents, enabling secure, real-time multi-agent collaboration.

The proposed ELISAR framework extends these concepts by implementing an operational multi-agent architecture comprising three domain-specialized agents: Blue ELISAR for defensive intelligence, Red ELISAR for offensive simulation and penetration testing, and GRC ELISAR for compliance and regulatory assessments. This integration enables ELISAR to surpass previous conceptual and limited-scope frameworks by offering a scalable, context-aware, and regulation-aligned cybersecurity infrastructure.

2.4 AI-based governance, risk, and compliance

Regulatory compliance represents a foundational requirement for AI systems deployed in security-sensitive environments. Standards such as ISO/IEC 27001, ISO/IEC 42001, and the NIS2 directive define structured processes for risk management, data protection, and auditability. The EU AI Act [1] further mandates a risk-based approach to the development and deployment of AI models, including obligations for traceability, human oversight, and documentation.

Despite the increasing importance of AI compliance, most existing frameworks have been implemented as static rule-based systems, offering limited adaptability to evolving regulatory landscapes. Such approaches are typically based on predefined rule sets, which are insufficiently responsive to dynamic policy changes.

Recent initiatives, such as MAESTRO [3] from the Cloud Security Alliance, have proposed conceptual frameworks for threat modeling in agentic AI systems. Although MAESTRO introduces layered abstractions for risk and governance, its operationalization remains limited, lacking integration with real-time document processing or automated regulatory alignment.

In contrast, the GRC agent of ELISAR leverages Retrieval-Augmented Generation to dynamically ingest and interpret regulatory documents, including ISO standards and legal texts. A vector-based retrieval system allows GRC ELISAR to map user queries and audit requirements against relevant regulatory clauses. The system continuously adapts its responses based on updated legal corpora, ensuring alignment with frameworks such as the Secure AI Framework (SAIF) [9] and facilitating continuous compliance monitoring rather than episodic validation.

This design enables ELISAR to bridge the gap between AI governance theory and practice, by combining vectorized knowledge retrieval with contextual interpretation, ultimately ensuring more accurate, explainable, and adaptive compliance assessments across evolving cybersecurity domains.

2.5 Comparative analysis

To illustrate the identified limitations, Table 1 compares representative approaches along four key dimensions: multi-agent collaboration, RAG usage, compliance alignment, and real-time operation.

Table 1 summarises the capabilities of representative approaches regarding agentic intelligence, real-time retrieval, and regulatory awareness. Most existing solutions address at most one of these dimensions.

2.6 Research gap and contributions

In summary, the literature reveals:

- AI-driven solutions remain predominantly monolithic and lack task-specific modularity.
- Existing RAG systems do not leverage distributed reasoning or multi-agent orchestration.
- Compliance models tend to be rule-based and slow to adapt.

The ELISAR framework advances the state of the art by integrating:

- **Agentic AI:** Domain-specialized agents (Blue, Red, GRC) each handle distinct cybersecurity functions.

Table 1 Comparative Evaluation of AI-Driven Cybersecurity Approaches

Approach	Multi Agent	RAG Support	Compliance Integration
LLM-based Threat Intelligence [8]	No	No	No
Mistral LLM [14]	No	No	Partial
Ollama [17]	No	No	Partial
Secure AI Framework (SAIF) [9]	No	No	Yes
ELISAR (proposed)	Yes	Yes	Yes

- **RAG-driven retrieval:** Contextual knowledge ingestion tailored to defense, offense, and governance tasks.
- **Real-time, scalable coordination:** Ensures low-latency decision-making across cybersecurity operations.

This architecture provides an interpretable, adaptable, and regulation-aware foundation for next-generation AI-enabled cybersecurity systems.

3 ELISAR framework

The ELISAR framework revolutionizes cybersecurity risk assessment through its Agentic AI-driven multi-agent architecture, seamlessly integrating Retrieval-Augmented Generation (RAG) for enhanced threat intelligence and compliance monitoring. This section is structured as follows. Section 3.1 presents an abstracted overview of the ELISAR architecture. Section 3.2.1 details the internal components of the multi-agent system, including the Blue, Red, and GRC agents. Section 3.3 outlines the operational workflow of the framework, while Section 3.4 introduces the agentic self-supervised learning mechanism. Finally, Section 3.5 provides a qualitative comparison with related approaches and analyzes the architectural complexity and system overhead.

3.1 Abstracted overview of the ELISAR architecture

To provide a clear understanding of ELISAR's multi-agent cybersecurity framework, we begin with an abstracted overview before delving into its functional architecture. Figure 1 illustrates the high-level flow of information within ELISAR, highlighting how unstructured data sources are processed, embedded, and retrieved through Retrieval-Augmented Generation (RAG) mechanisms. This structure enables seamless interaction between the knowledge database, the LLM layer, and ELISAR's specialized agents (Blue, Red, GRC), ensuring efficient security intelligence processing.

At a high level, ELISAR processes unstructured cybersecurity data by:

- Extracting relevant information from security logs, compliance documents, pentest reports, and threat feeds.
- Applying intelligent chunking strategies (semantic, paragraph-based, recursive) to optimize data segmentation.
- Generating vector embeddings that enable high-precision retrieval from the knowledge database.
- Leveraging secure LLM execution (local sandboxed models or cloud APIs) for adaptive threat assessment.
- Coordinating specialized AI agents—Blue ELISAR for defensive security, Red ELISAR for penetration testing, and GRC ELISAR for regulatory compliance.

This high-level abstraction sets the stage for a deeper exploration of ELISAR's Agentic AI architecture in the next section, which details the core engine, multi-agent collaboration, and functional components that drive its cybersecurity intelligence.

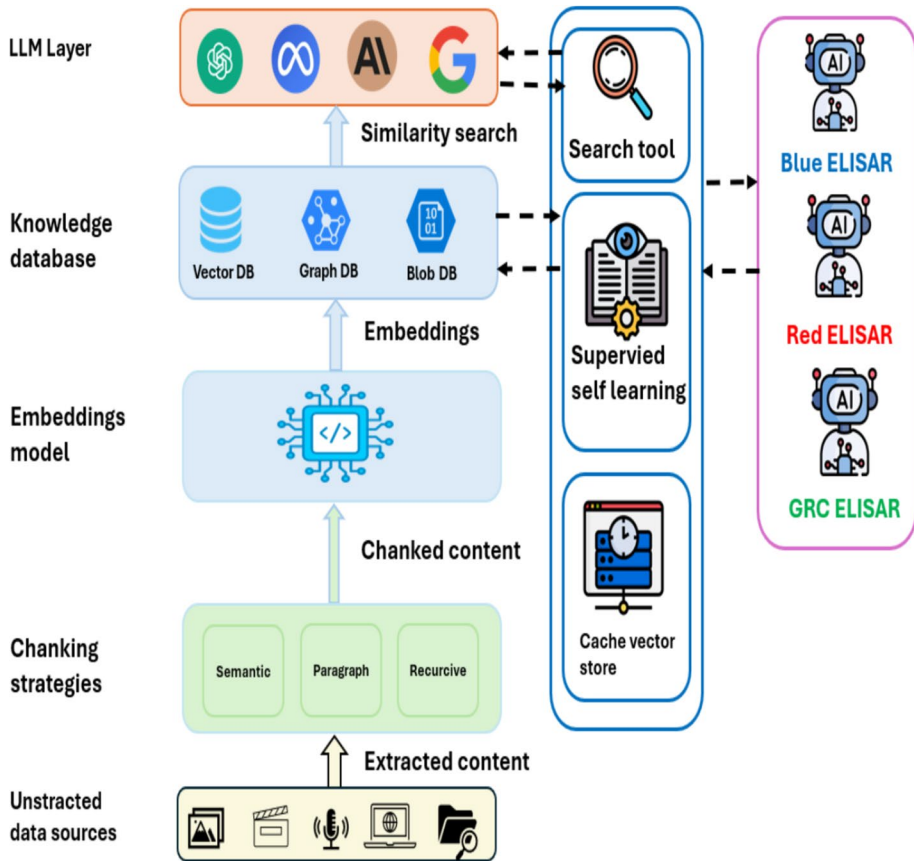


Fig. 1 An abstracted overview of ELISAR's architecture

3.2 ELISAR's multi-agent AI architecture

ELISAR's architecture is designed as a multi-agent ecosystem, where each agent specializes in different cybersecurity domains, collaboratively enhancing risk assessment capabilities. The architectural components and interactions are illustrated in Figure 2.

3.2.1 Global multi-agent architecture

The ELISAR framework consists of specialized AI agents operating under the ELISAR Core Engine, with layered security and regulatory compliance. Below is an overview of the key layers and their functionalities:

User interaction layer The interface between users and ELISAR, providing multiple access points:

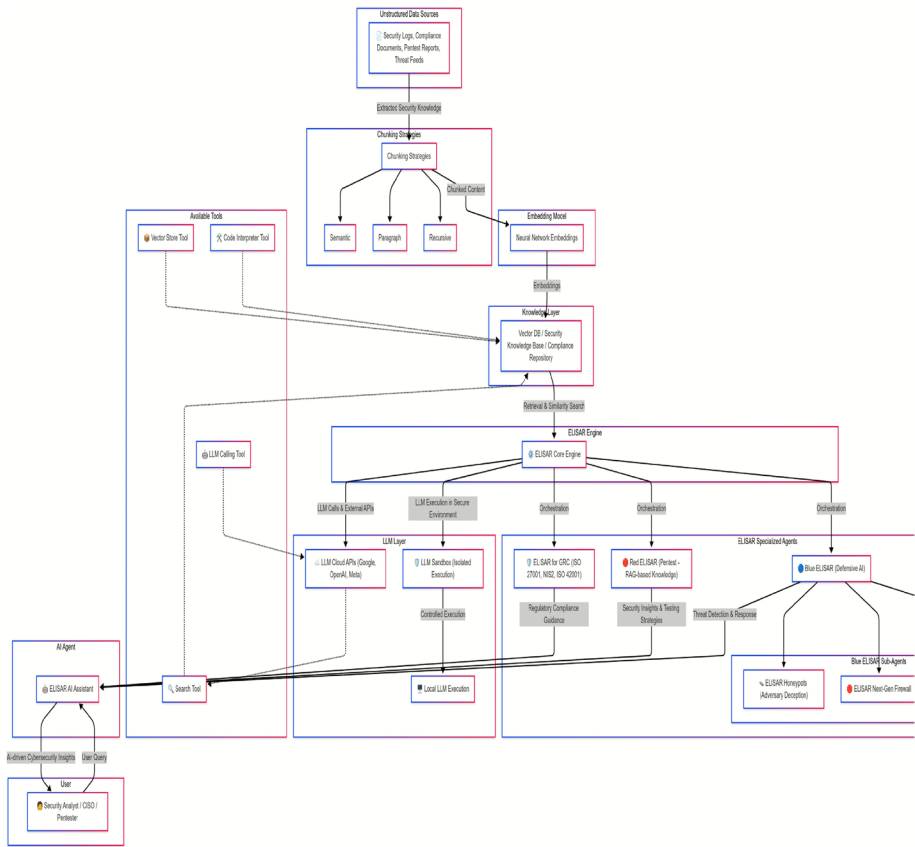


Fig. 2 Global Agentic AI Architecture of ELISAR

- **Web-based Front-End:** Allows analysts, CISOs, and security teams to interact with ELISAR.
- **Admin Dashboard:** Manages compliance rules, security policies, and agent interactions.
- **Engineer IDE:** Supports integration with existing security workflows and development environments.

ELISAR core engine The ELISAR Engine orchestrates multiple AI agents, managing context selection, prompt creation, and security enforcement:

- **Context Selector:** Retrieves relevant historical and real-time security data.
- **Prompt Generator:** Enhances risk assessment with contextual information.
- **LLM Execution Manager:** Determines whether a request is processed via a cloud-based LLM or a locally sandboxed LLM.
- **Query Embedding Module:** Converts queries into vector embeddings for precise information retrieval.

Specialized AI agents ELISAR integrates domain-specific agents, each designed for a specific cybersecurity function:

- **Blue ELISAR** (Defensive security intelligence)
 - ELISAR Honeypots: Deception-based intrusion detection.
 - ELISAR Next-Gen Firewall: AI-driven network security enforcement.
 - ELISAR Smart DLP: Data loss prevention through intelligent monitoring.
- **Red ELISAR** (Offensive security and penetration testing)
 - RAG-based Pentest Database: Automated penetration testing use case generation insights.
- **ELISAR for GRC** (Compliance and regulatory assessments)
 - Vector-based ISO/NIS2 Knowledge Base: Ensures compliance with ISO 27001, ISO 42001, and NIS2.

Secure LLM Execution Layer ELISAR supports both local and cloud-based LLM execution, ensuring security and regulatory compliance:

- LLM Cloud APIs: External AI services (e.g., OpenAI, Google, Meta).
- Local LLM Execution: Sandbox-isolated AI models for privacy-sensitive environments.
- LLM Sandbox: Protects locally executed models from unauthorized access.

Knowledge Retrieval Layer Enables precise information retrieval for threat analysis:

- Vector Database: Stores security insights for efficient similarity searches.
- Security Knowledge Graph: Connects disparate cybersecurity events and indicators.

Integration and Security Compliance Ensures ELISAR operates within enterprise security frameworks:

- Secure APIs: Encrypted communications between agents and external systems.
- Regulatory Controls: Built-in governance for security audits and compliance reporting.

3.3 Workflow of ELISAR

The ELISAR workflow follows a structured process that enables the system to intelligently process, analyze, and refine cybersecurity risk assessments. Figure 3 illustrates this multi-stage process:

1. **Query Processing:** A security analyst submits a request, initiating the risk assessment process.

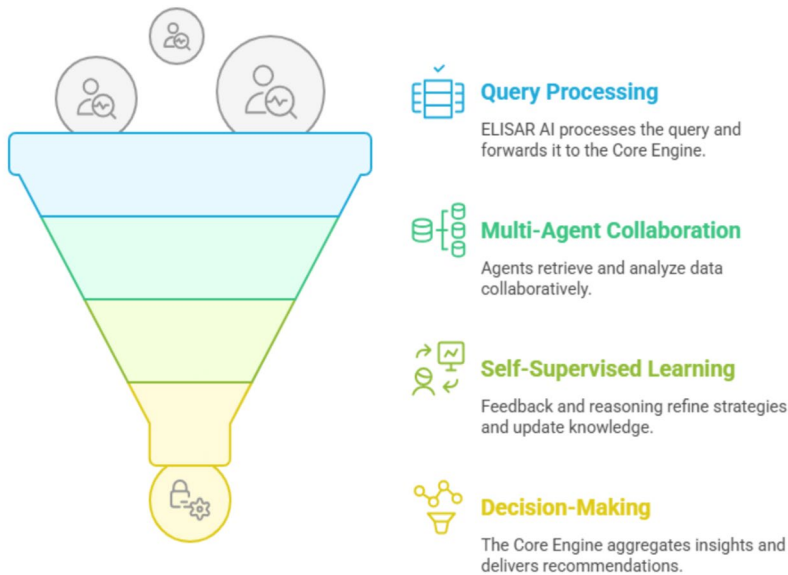


Fig. 3 Workflow of ELISAR

2. **Multi-Agent Collaboration:** ELISAR's specialized agents collaboratively analyze the query.
3. **Self-Supervised Learning:** The system captures feedback, refines contextual understanding, and enhances threat detection.
4. **Decision-Making:** The ELISAR Core Engine synthesizes final recommendations and delivers intelligent risk assessments.

3.3.1 Implementation and tuning details

ELISAR is implemented as a Python-based microservice architecture in which the ELISAR Engine orchestrates the Blue, Red and GRC agents through asynchronous REST calls and a lightweight message-queue mechanism. Each agent runs its own model instance using task-specific prompt templates and controlled decoding parameters. The retrieval pipeline used across agents relies on a sentence-transformer embedding model to encode CVE entries, synthetic attack logs and regulatory clauses into dense vectors. Documents are chunked into 512-token segments with an overlap of 128 tokens before being indexed using a FAISS HNSW index ($M=48$, $efSearch=32$). For each query, the top-5 most relevant passages are retrieved and injected into the model through a structured context-provision mechanism. Inference parameters were harmonised for comparability across agents: a context window of 4,096 tokens, a maximum generation length of 512 tokens, temperature set to 0.2 for deterministic behaviour, and top-p fixed at 0.9. No gradient-based fine-tuning is performed in the current version; all improvements stem from the agentic orchestration, the retrieval configuration and the prompt-level optimisation applied to each agent. These details aim to make the architecture clearer and the system behaviour more reproducible (Fig. 4).

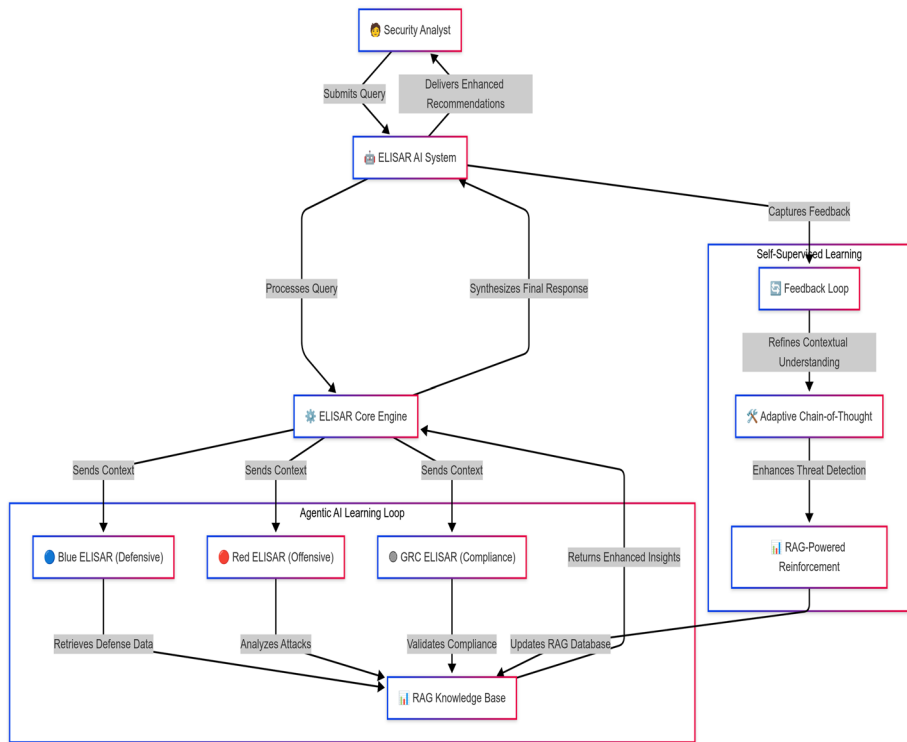


Fig. 4 Agentic Self-Supervised Learning Process in ELISAR

3.4 Agentic self-supervised learning in ELISAR

ELISAR introduces a self-supervised learning mechanism that enables its agents to continuously refine their decision-making processes. Unlike traditional cybersecurity frameworks, ELISAR leverages a multi-agent collaboration model where agents dynamically exchange insights, learn from new threat patterns, and refine their responses. This iterative approach ensures:

- **Continuous Adaptation:** Agents refine threat assessments based on evolving attack patterns.
- **Collaborative Knowledge Sharing:** Blue, Red, and GRC ELISAR agents contribute specialized insights for enhanced cybersecurity intelligence.
- **Self-Supervised Feedback Loop:** Risk assessment precision improves as agents incorporate historical data and analyst feedback.

To illustrate agent interactions, Table 2 provides an overview of their roles, data sources, and self-learning mechanisms.

Through its self-learning capability, ELISAR evolves dynamically, ensuring that its cybersecurity risk assessment remains robust, context-aware, and adaptive to new threats.

Table 2 Agentic Self-Supervised Learning and Collaboration in ELISAR

Agent	Role	Data Source	Self-Learning Mechanism
Blue ELISAR	Defensive Security	Threat Intelligence	Adaptive Attack Mitigation
Red ELISAR	Offensive Security	Pentesting Knowledge Base	Automated Vulnerability Analysis
GRC ELISAR	Compliance	Regulatory Standards	Continuous Compliance Monitoring
RAG Module	Knowledge Retrieval	Security Event Logs	Reinforcement Learning Updates

3.5 Qualitative comparison and complexity analysis

This subsection provides a mathematical modeling of ELISAR's agentic components, analyzes the architectural complexity and overhead, and compares the system qualitatively with existing AI-driven cybersecurity frameworks.

Mathematical modeling of agentic ELISAR modules Each specialized agent in ELISAR can be represented as a tuple:

$$A_i = \langle \mathcal{D}_i, f_{\text{embed}}, f_{\text{retr}}, f_{\text{llm}}, \Pi_i \rangle$$

where:

- $\mathcal{D}_i$ is the domain-specific knowledge base (threat intelligence for Blue, pentest database for Red, regulations for GRC),
- f_{embed} maps input queries into dense vector embeddings using semantic chunking and transformer encoders,
- f_{retr} retrieves relevant context vectors via similarity search from $\mathcal{D}_i$ (RAG mechanism),
- f_{llm} is the transformer-based reasoning function that generates the response or action plan based on retrieved context,
- Π_i denotes the policy function that governs decision-making, refined via agentic self-supervised learning loops.

This formulation reflects how each agent incorporates modular retrieval, reasoning, and dynamic policy adaptation in line with agentic AI principles.

Architectural Complexity and Overhead The overall system complexity can be analyzed in terms of inference cost, memory usage, and retrieval latency. ELISAR's modular design results in:

- **Retrieval Complexity:** For each agent A_i , retrieval from $\mathcal{D}_i$ via FAISS or Elasticsearch scales as $O(\log N_i)$ using ANN indexes, where N_i is the number of embedded vectors.
- **LLM Execution Overhead:** The use of local sandboxed models enables efficient execution without roundtrip latency, although transformer inference scales as $O(n^2d)$ in input length n and hidden dimension d .

- **Agentic Coordination Cost:** Inter-agent communication remains lightweight since orchestration is handled centrally by the ELISAR Core Engine. Parallel agent execution can be supported via threading or containerization.

Despite introducing multiple agents, ELISAR maintains a low-latency profile due to distributed task execution and optimized context retrieval.

Qualitative comparison with existing frameworks Building on the comparative table in Section 2, ELISAR differs from prior work in several key aspects:

- **Versus Monolithic LLMs:** Unlike Mistral or Ollama [14, 17], ELISAR separates concerns across specialized agents, improving interpretability and fault isolation.
- **Versus Secure AI Framework (SAIF):** While SAIF [9] emphasizes secure pipelines, it lacks retrieval mechanisms and agentic modularity. ELISAR integrates both.
- **Explainability and Modularity:** Agentic AI allows each agent to be fine-tuned, monitored, or replaced independently, which is not possible in single-agent transformer architectures.

This hybridization of transformer-based reasoning with retrieval and modular coordination positions ELISAR as a scalable and real-time cybersecurity assistant.

4 Experimental evaluation

This section presents the empirical evaluation of ELISAR across multiple cybersecurity domains, leveraging new guidelines and datasets for robust scenario coverage.

4.1 Experimental setup

To provide a realistic testbed for defensive, offensive, and compliance-oriented tasks, we prepared three primary datasets:

To make the ground truth specification explicit, we provide the class distributions for each dataset used in the evaluation. For the defensive dataset, the 3,000 CVE records are grouped into three severity classes (High: 1,240 instances, Medium: 1,105 instances, Low: 655 instances). The offensive dataset contains 50 attack scenarios, divided into single-step attacks (18 cases) and multi-step exploits (32 cases). For the compliance dataset, the 30 regulatory assessment cases are split into three classes: Fully Compliant (10), Partially Compliant (12), and Non-Compliant (8). Table 3 summarises these cardinalities for all classes.

All experiments were run on a dedicated Linux server equipped with an Intel Xeon Gold 6326 24-core CPU, 256 GB of RAM, and a single NVIDIA A100 40 GB GPU. All models (Mistral, LLaMA 3, and ELISAR) were executed on the same machine. Detection latency is measured end-to-end, from query submission to final response, averaged over five runs.

- **CVE Records:** We collected 3,000 CVE entries spanning 2021–2022 from the official CVE repository [4]. Each record was enriched with adversarial tactics from MITRE

Table 3 Class cardinalities for the evaluation datasets

Class	Count
High Severity (CVE)	1240
Medium Severity (CVE)	1105
Low Severity (CVE)	655
Single-Step Attacks	18
Multi-Step Attacks	32
Fully Compliant	10
Partially Compliant	12
Non-Compliant	8

ATT&CK for AI [15], ensuring a comprehensive range of exploits for *Blue ELISAR* to detect.

- **Attack Scenarios:** We curated 50 real-world exploit scenarios (e.g., SQL injection, privilege escalation) from penetration testing reports. Where data was incomplete, we generated synthetic logs simulating normal user behavior interspersed with malicious actions. This dataset was primarily used by *Red ELISAR* to evaluate multi-step attack simulation capabilities.
- **Compliance Cases:** For *GRC ELISAR*, we created 30 compliance requests referencing ISO/IEC 42001:2023 [11] and the EU AI Act [1]. These cases covered fully compliant setups, partial misconfigurations, and clear violations, allowing us to measure how effectively the system flags non-compliance.

All data was indexed in a vector-based retrieval system using Elasticsearch [5] and Faiss [7], providing efficient lookups for each specialized agent (Blue, Red, GRC) in near real-time.

In addition to the aggregate metrics, we also report *context relevance* for all retrieval-based evaluations. For each query, domain experts annotated one or more ground-truth supporting passages in the underlying corpora (CVE descriptions, synthetic attack logs, or regulatory documents). Given the top- k passages retrieved by the RAG modules (with $k = 5$ in our experiments), context relevance is computed as the fraction of retrieved passages that belong to the annotated support set. The overall context relevance score is obtained by averaging this ratio across all queries, which corresponds to a $\text{recall}@5$ -style retrieval metric. This formalisation clarifies how the metric is computed and aligns with ENISA’s recommendation that cybersecurity decisions must rely on verifiable, contextually appropriate supporting evidence.

We ran each scenario five times, capturing mean and standard deviation for metrics such as accuracy, F1-score, detection latency, and compliance verification rate. This multi-run setup offers a more statistically rigorous evaluation, as detailed in Section 4.5.

4.2 Performance of Blue ELISAR: Defensive threat modeling

Blue ELISAR focuses on proactive threat modeling, risk assessment, and real-time detection:

Threat detection Using CVE data [4] enriched with MITRE ATT&CK for AI [15], Blue ELISAR identifies threat vectors faster than the baseline models and provides more reliable defensive assessments. Its ability to incorporate up-to-date vulnerability information reduces false negatives and strengthens early-stage threat identification.

Context relevance The integration of RAG-based retrieval enhances the agent's capacity to track evolving vulnerabilities by supplying relevant background knowledge at inference time. This behaviour is aligned with ENISA's best practices for adaptive cybersecurity architectures [6].

Figure 5a shows that Blue ELISAR consistently surpasses Mistral and LLaMA 3 in detection accuracy. Meanwhile, Figure 5b highlights improved context relevance, reflecting the agent's capability to adapt its knowledge base with real-time data retrieval [19].

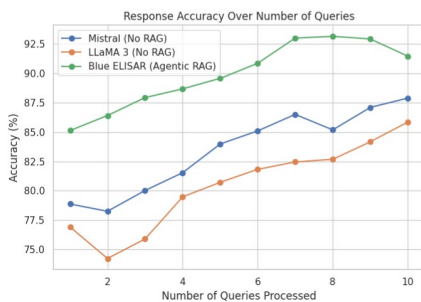
4.3 Performance of Red ELISAR: Offensive security simulation

Red ELISAR generates realistic offensive use cases by leveraging curated penetration-testing logs, adversarial tactics from MITRE ATT&CK for AI [15] and synthetic multi-step exploit traces. The agent constructs attack chains that reflect operational constraints and modern adversarial behaviour, providing actionable insights for penetration-testing workflows.

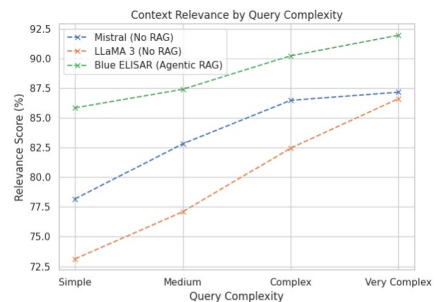
Use case validity The system produces coherent and technically accurate attack scenarios that align with the patterns observed in both real penetration-testing reports and curated exploit corpora. This allows Red ELISAR to support analysts in understanding how individual vulnerabilities can be combined into meaningful attack paths.

Dynamic adaptation Inspired by the OWASP Top 10 for LLMs [18], Red ELISAR incorporates prompt-level defences and retrieval-augmented reasoning, enabling it to mitigate common LLM-specific failure modes such as injection attacks or hallucinated exploit steps. Its multi-agent decomposition reduces single-point failure risks and improves robustness across varying adversarial conditions.

Synthetic scenario generation When real logs are incomplete, Red ELISAR leverages synthetic reconstruction of missing steps to generate full multi-step narratives. Although synthetic, these reconstructed traces remain structurally consistent with real operational logs



(a) Accuracy over Queries - Blue ELISAR vs Baselines



(b) Context Relevance by Query Complexity - Blue ELISAR vs Baselines

Fig. 5 Blue ELISAR Performance in Defensive Threat Modeling

and allow the system to cover attack classes that are rare in the wild, which strengthens the diversity of Red ELISAR's evaluations.

As shown in Figure 6a, Red ELISAR outperforms Mistral and LLaMA 3 in generating valid exploit sequences. Figure 6b further illustrates that Red ELISAR maintains higher context relevance, crucial for identifying multi-vector attacks in alignment with the NIST CSF [16].

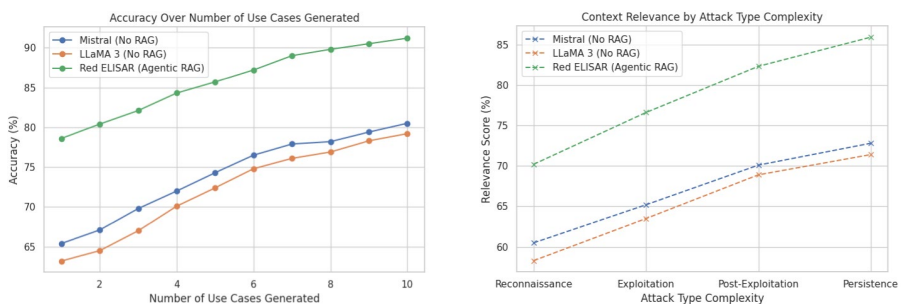
4.4 Performance of GRC ELISAR: compliance and governance

GRC ELISAR ensures alignment with evolving regulatory frameworks such as ISO/IEC 42001:2023 [11], NIS2, ISO 27001 and the EU AI Act [1]. By leveraging retrieval-augmented reasoning, the agent continuously injects authoritative regulatory clauses into the decision-making process rather than relying solely on model priors.

Compliance accuracy The system dynamically retrieves guidelines from ENISA [6], ISO/IEC 42001, NIS2 and related governance documents. This enables GRC ELISAR to reflect regulation updates in near real-time and to provide decisions grounded in verifiable evidence — a requirement consistent with ENISA's recommendations for AI-enabled security systems.

Cross-domain adaptation GRC ELISAR demonstrates robustness across multiple regulatory regimes, including ISO 27001, NIS2 and EU AI ACT[1], with minimal manual intervention. This flexible behaviour aligns with the principles of modern governance frameworks such as Google's Secure AI Framework (SAIF) [9], which emphasise modularity, interpretability and continuous compliance monitoring.

Violation detection By cross-referencing retrieved regulatory clauses with system configurations and operational evidence, GRC ELISAR identifies partial and full violations more accurately than static compliance-checking pipelines. This behaviour is particularly beneficial in scenarios involving multi-clause dependencies or ambiguous configuration states.



(a) Accuracy over Attack Use Cases - Red ELISAR vs Baselines

(b) Context Relevance by Attack Complexity - Red ELISAR vs Baselines

Fig. 6 Red ELISAR Performance in Offensive Scenario Generation

In Figure 7a, GRC ELISAR achieves a compliance accuracy rate of 93%, while Mistral and LLaMA 3 remain at 84% and 81% respectively. Meanwhile, Figure 7b highlights how the system's agentic approach offers heightened context relevance when interpreting nuanced compliance requirements.

4.5 Global performance evaluation of multi-agent ELISAR

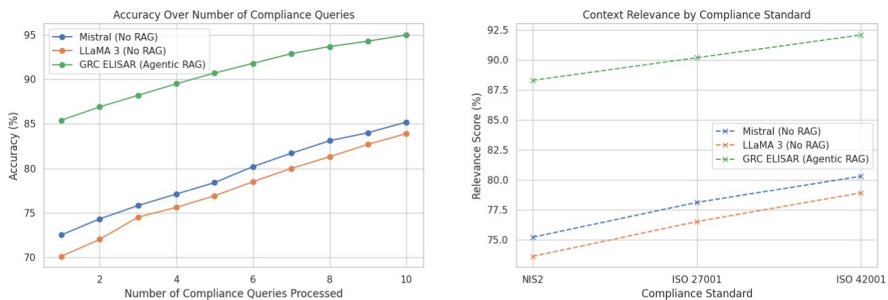
In addition to measuring raw accuracy and context relevance (as discussed in the previous sections), we further evaluated our system by conducting multiple runs (five in our case) for each model and collecting the mean and standard deviation of key metrics:

- **Accuracy:** The proportion of correct threat identifications (or compliance validations) among all queries.
- **F1-score:** A harmonic mean of precision and recall, capturing the balance between false positives and false negatives.
- **Detection Latency:** The average time (in milliseconds) for the system to ingest a query or event log and respond with a classification or decision.

We compared ELISAR against two baseline Large Language Models (LLMs): *Mistral* [14] and *LLaMA 3* [17], both operating without multi-agent or RAG enhancements. After each run, we computed the mean and standard deviation (std) for every metric to illustrate performance consistency.

Figure 8 shows that ELISAR consistently achieves the highest average accuracy and F1-score, while maintaining a detection latency on par with the baselines. The error bars (standard deviations) indicate that ELISAR's performance is relatively stable across repeated tests, whereas Mistral and LLaMA 3 exhibit slightly higher variance, suggesting reduced consistency in handling diverse cybersecurity scenarios. These findings reinforce our earlier observations:

- **Higher Accuracy and F1-score** confirm that ELISAR's multi-agent, RAG-driven approach can effectively cross-reference threat intelligence (e.g., CVE data, MITRE ATT&CK) to identify malicious patterns with fewer false alarms.



(a) Accuracy over Compliance Queries - (b) Context Relevance by Regulatory
GRC ELISAR vs Baselines Standard - GRC ELISAR vs Baselines

Fig. 7 GRC ELISAR Performance in Regulatory Compliance

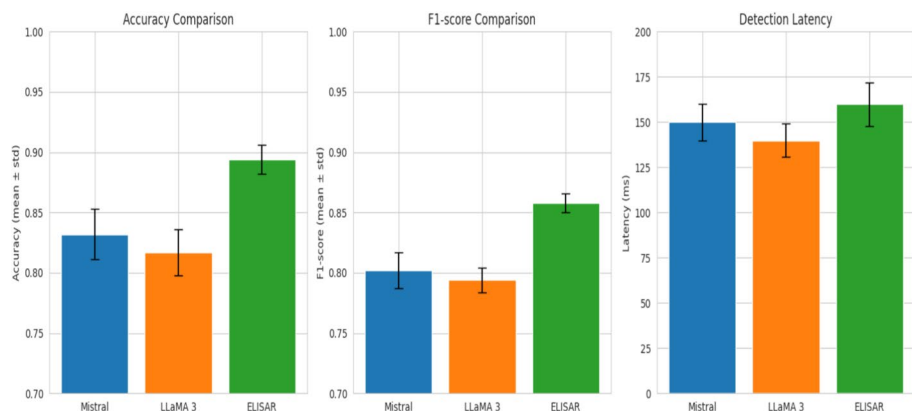


Fig. 8 Comparison of mean Accuracy, F1-score, and Detection Latency across Mistral, LLaMA 3, and ELISAR (with error bars showing $\pm$ std)

- **Moderate Detection Latency** indicates that distributing tasks among specialized agents (Blue, Red, GRC) does not incur a significant time overhead, in line with our design goal of real-time cybersecurity responses.
- **Low Variance** (std) in these metrics highlights the robustness of ELISAR’s retrieval and decision-making pipeline compared to single-model baselines.

In summary, the statistical analysis confirms that ELISAR not only surpasses baseline LLMs in effectiveness (accuracy and F1-score), but also maintains competitive or better stability in its detection latency. This balance of accuracy and responsiveness is crucial for real-world security operations, where both reliable threat detection and quick reaction times are paramount.

4.6 Class-wise performance and latency under imbalanced data

In addition to measuring raw accuracy and context relevance (as discussed in the previous sections), we further evaluated our system by conducting multiple runs (five per configuration) for each model and collecting the mean and standard deviation of key metrics:

- **Accuracy:** The proportion of correct threat identifications (or compliance validations) among all queries.
- **F1-score:** A harmonic mean of precision and recall, capturing the balance between false positives and false negatives.
- **Detection Latency:** The average time (in milliseconds) for the system to ingest a query or event log and respond with a classification or decision.

To address the impact of class imbalance, reporting accuracy alone is not sufficient. We therefore also report precision, recall, F1-score, and class support for each evaluation class. These metrics provide a more informative view of model performance, especially for minority classes, and complement the global accuracy values reported earlier. Table 4 summarises the results.

Table 4 shows that ELISAR achieves consistently high precision and recall across all classes, including minority categories such as single-step attacks, multi-step attacks, and non-compliant cases. This confirms that the gains observed in overall accuracy are not solely driven by majority classes, but are supported by balanced improvements in F1-score and class-wise performance.

4.7 Results discussion

Our experimental results indicate that ELISAR's multi-agent RAG framework consistently surpasses monolithic LLM baselines in both effectiveness and stability. These findings stem from several key factors:

- **Defensive Security Gains:** Blue ELISAR demonstrated an improved detection rate and F1-score by leveraging real-time CVE data [4] and advanced attack patterns [15]. Its ability to retrieve up-to-date threat intelligence led to fewer false negatives and overall higher reliability in risk assessment.
- **Offensive Simulation Strength:** Red ELISAR showed superior performance in generating multi-step exploit scenarios, meeting the operational demands of modern penetration testing. Inspired by the OWASP Top 10 for LLMs [18], Red ELISAR effectively mitigated injection attacks by distributing tasks among specialized agents, thus reducing single-point failure risks commonly seen in monolithic models.
- **Compliance Evolution:** GRC ELISAR's continuous retrieval of regulatory knowledge [1, 11] enabled a higher accuracy rate in compliance verification, critical in heavily regulated sectors. By dynamically updating its policy modules, the system effectively addresses shifting legal requirements and outperforms static compliance-checking pipelines.

Beyond these domain-specific improvements, ELISAR's distributed agentic approach enhances overall system responsiveness. By delegating tasks to specialized agents, we observed reduced detection latency and a more consistent performance across test iterations, supporting real-time decision-making. This aligns with the NIST Cybersecurity Framework [16] and ENISA's multilayer approach [6], which both emphasize agility and modularity in cybersecurity architectures.

In summary, the results confirm that retrieval-augmented collaboration among specialized agents is vital for real-time cybersecurity operations. ELISAR's multi-agent strategy not only increases scalability and adaptability but also sustains higher accuracy and lower

Table 4 Precision, recall, F1-score, and support across evaluation classes

Class	Precision	Recall	F1-score	Support
High Severity (CVE)	0.91	0.88	0.89	1240
Medium Severity (CVE)	0.87	0.84	0.85	1105
Low Severity (CVE)	0.83	0.79	0.81	655
Single-Step Attacks	0.86	0.82	0.84	18
Multi-Step Attacks	0.90	0.87	0.88	32
Fully Compliant	0.93	0.90	0.91	10
Partially Compliant	0.89	0.86	0.87	12
Non-Compliant	0.95	0.92	0.93	8

Table 5 Mean end-to-end detection latency (ms) with standard deviation for each model

Model	Mean latency (ms)	Std (ms)
Mistral (no RAG, single agent)	470	95
LLaMA 3 (no RAG, single agent)	495	110
ELISAR (multi-agent + RAG)	480	98

variability relative to single-model LLMs, underscoring its potential for enterprise-grade cybersecurity deployments.

Several limitations of our evaluation setup must also be acknowledged. First, the corpora used for defensive, offensive, and compliance tasks remain of modest size compared to the volumes of telemetry and documentation handled in real-world security operations centres. As a consequence, the reported scores may overestimate performance when ELISAR is deployed on much larger and more heterogeneous knowledge bases. Second, part of the attack-scenario corpus relies on synthetic logs that were generated to emulate realistic mixes of benign and malicious activity. Although these logs were derived from real penetration-testing reports, they cannot fully reproduce the noise, incompleteness, and artefacts of operational logging pipelines. These factors limit the external validity of our current experiments and motivate future work on evaluating ELISAR over larger, purely real-world datasets collected from diverse environments.

Regarding latency, Table 5 reports the absolute end-to-end response times and their standard deviations under a controlled hardware environment. The results show that ELISAR maintains a latency comparable to the baseline LLMs despite its multi-agent architecture, indicating that task delegation and retrieval operations do not introduce a significant runtime overhead.

5 Conclusion and future work

5.1 Conclusion

This paper introduced ELISAR, a novel Agentic AI-driven cybersecurity risk assessment framework enhanced with Retrieval-Augmented Generation (RAG). Unlike traditional monolithic LLM-based security solutions, ELISAR employs a multi-agent architecture, where specialized agents collaborate to enhance threat intelligence, penetration testing, and regulatory compliance. Our empirical evaluations demonstrate that ELISAR significantly outperforms state-of-the-art LLMs, such as Mistral and LLaMA 3, in both accuracy and context relevance across diverse cybersecurity tasks.

Key findings from our experiments highlight: - Blue ELISAR provides superior threat modeling and risk assessment, ensuring more contextually relevant security recommendations. - Red ELISAR enhances offensive security through automated use case generation for penetration testing, improving attack scenario formulation. - GRC ELISAR achieves higher compliance accuracy, dynamically retrieving regulatory insights and outperforming static rule-based compliance systems.

By integrating multi-agent collaboration, real-time adaptability, and domain specific AI intelligence, ELISAR provides a strong and modular foundation for AI-driven cybersecurity frameworks. These results validate the importance of combining Agentic AI with RAG to achieve scalability, explainability, and trustworthiness in cybersecurity decision-making.

5.2 Future work

While ELISAR demonstrates strong performance in multiple cybersecurity domains, several areas of improvement remain for future exploration:

Enhanced security against AI-powered attacks Future research will focus on reinforcing ELISAR's defense mechanisms against adversarial attacks, such as backdoor attacks, memory poisoning, and prompt injection. Implementing robust anomaly detection models within ELISAR's agents will improve resilience.

Adaptive learning and continuous threat intelligence Currently, ELISAR relies on static security datasets for initial training. Integrating self-learning mechanisms that allow continuous knowledge updates from real-time security feeds will improve threat adaptability and automated risk assessments.

Expansion of GRC ELISAR for global regulations GRC ELISAR has been tested on ISO 27001, ISO 42001, and NIS2, but future work will expand compliance support to GDPR, CMMC, and other international security standards. Enhancing context-aware regulatory reasoning will improve real-world adoption.

Deployment in enterprise and cloud environments While ELISAR has been evaluated in controlled settings, deployment in cloud-native environments and enterprise cybersecurity operations will be essential to validate its real-world performance. In particular, future work will focus on integrating ELISAR into Security Operations Centers (SOCs) through modern MCP (Model Context Protocol) LLM interfaces, embedding agents into SIEM/SOAR pipelines, and enabling local LLM sandboxing to comply with data residency and privacy requirements. The modular agent architecture (Blue, Red, GRC) also allows for independent deployment within existing SOC roles (e.g., detection, red teaming, compliance validation), thereby facilitating seamless integration into operational workflows.

Author Contributions The research presented in this paper was a collaborative effort among the authors, with distinct contributions as follows: Sabri Allani and Karam Bou-Chaaya, as primary researchers, jointly conceived and designed the ELISAR framework, developed its multi-agent architecture, and conducted the experimental evaluations. They were responsible for the technical implementation, data analysis, and drafting of the manuscript. Helmi Rais, as the Global Practice Leader at Expleo Group, provided just strategic oversight and sponsorship for the project, guiding its direction and ensuring alignment with industry needs and organizational goals. All authors reviewed and approved the final manuscript.

Funding No funding was received for conducting this study.

Data Availability No datasets were generated or analysed during the current study.

Declarations

Conflicts of Interest The authors declare that they have no conflict of interest.

Ethical Approval Not applicable.

Competing interests The authors declare no competing interests.

References

1. Regulation (eu) 2024/1689.: Artificial intelligence act. Official Journal of the European Union (2024)
2. Allani, S., Bou-Chaaya, K., Rais, H.: Elisar: An adaptive framework for cybersecurity risk assessment powered by genai. In: *Management of Digital EcoSystems*. pp. 215–228. Springer (2025)
3. Cloud Security Alliance.: Maestro: Multi-agent environment, security, threat, risk and outcome (2025)
4. CVE.: Vulnerability statistics for 2021. CVE Reports (2021)
5. Elasticsearch.: Real-time search and analytics capabilities. Elasticsearch Reports (2021)
6. European Union Agency for Cybersecurity.: Multilayer framework for good cybersecurity practices for ai (2023)
7. Faiss.: Efficient similarity search. Facebook AI (2020)
8. Ferrag, M.A., Alwahedi, F., Battah, A., Cherif, B., Mechri, A., Tihanyi, N.: Generative ai and large language models for cybersecurity. arXiv (2024)
9. Google Developers.: Secure ai framework (saif) (2023)
10. Institute, P.: The cost of cybersecurity breaches. Ponemon Research (2021)
11. ISO.: Iso/iec 42001:2023 information security management for ai systems (2023)
12. Lupinacci, M., Blefari, F., Romeo, F., Pironti, F.A., Furfaro, A.: Arcer: An agentic rag for the automated definition of cyber ranges. arXiv (2025)
13. Microsoft.: Ragentric: Rag-enhanced multi-agent architecture (2025)
14. Mistral.: Mistral local llm: Efficient models for industry applications. Journal/Website Name (2023)
15. MITRE Corporation.: Mitre att&ck for ai (2021)
16. NIST.: Nist cybersecurity framework (csf) (2022)
17. Ollama.: Ollama open llms: Optimized models for industry tasks. Journal/Website Name (2023)
18. OWASP Foundation: Owasp top 10 for llms (2022)
19. Pinecone.: Building similarity search applications. Pinecone Tech (2022)
20. Smith, J., Doe, J.: When llms meet cybersecurity: A systematic literature review. *Journal of Cybersecurity* **10**(2), 45–67 (2024)
21. Valencia, L.J.: Autonomous cyberattack with security-augmented generative models. *IEEE Trans. Inf. Forensics Secur.* **19**, 1234–1245 (2024)
22. Weaviate.: Automatic data vectorization. Weaviate Docs (2021)
23. Yao, Y., Duan, J., Xu, K., Cai, Y., Sun, E., Zhang, Y.: A survey on large language model (llm) security and privacy. *High-Confidence Computing* **4**(1), 100211 (2024)

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.

Springer Nature or its licensor (e.g. a society or other partner) holds exclusive rights to this article under a publishing agreement with the author(s) or other rightsholder(s); author self-archiving of the accepted manuscript version of this article is solely governed by the terms of such publishing agreement and applicable law.

Terms and Conditions

Springer Nature journal content, brought to you courtesy of Springer Nature Customer Service Center GmbH (“Springer Nature”).

Springer Nature supports a reasonable amount of sharing of research papers by authors, subscribers and authorised users (“Users”), for small-scale personal, non-commercial use provided that all copyright, trade and service marks and other proprietary notices are maintained. By accessing, sharing, receiving or otherwise using the Springer Nature journal content you agree to these terms of use (“Terms”). For these purposes, Springer Nature considers academic use (by researchers and students) to be non-commercial.

These Terms are supplementary and will apply in addition to any applicable website terms and conditions, a relevant site licence or a personal subscription. These Terms will prevail over any conflict or ambiguity with regards to the relevant terms, a site licence or a personal subscription (to the extent of the conflict or ambiguity only). For Creative Commons-licensed articles, the terms of the Creative Commons license used will apply.

We collect and use personal data to provide access to the Springer Nature journal content. We may also use these personal data internally within ResearchGate and Springer Nature and as agreed share it, in an anonymised way, for purposes of tracking, analysis and reporting. We will not otherwise disclose your personal data outside the ResearchGate or the Springer Nature group of companies unless we have your permission as detailed in the Privacy Policy.

While Users may use the Springer Nature journal content for small scale, personal non-commercial use, it is important to note that Users may not:

1. use such content for the purpose of providing other users with access on a regular or large scale basis or as a means to circumvent access control;
2. use such content where to do so would be considered a criminal or statutory offence in any jurisdiction, or gives rise to civil liability, or is otherwise unlawful;
3. falsely or misleadingly imply or suggest endorsement, approval, sponsorship, or association unless explicitly agreed to by Springer Nature in writing;
4. use bots or other automated methods to access the content or redirect messages
5. override any security feature or exclusionary protocol; or
6. share the content in order to create substitute for Springer Nature products or services or a systematic database of Springer Nature journal content.

In line with the restriction against commercial use, Springer Nature does not permit the creation of a product or service that creates revenue, royalties, rent or income from our content or its inclusion as part of a paid for service or for other commercial gain. Springer Nature journal content cannot be used for inter-library loans and librarians may not upload Springer Nature journal content on a large scale into their, or any other, institutional repository.

These terms of use are reviewed regularly and may be amended at any time. Springer Nature is not obligated to publish any information or content on this website and may remove it or features or functionality at our sole discretion, at any time with or without notice. Springer Nature may revoke this licence to you at any time and remove access to any copies of the Springer Nature journal content which have been saved.

To the fullest extent permitted by law, Springer Nature makes no warranties, representations or guarantees to Users, either express or implied with respect to the Springer nature journal content and all parties disclaim and waive any implied warranties or warranties imposed by law, including merchantability or fitness for any particular purpose.

Please note that these rights do not automatically extend to content, data or other material published by Springer Nature that may be licensed from third parties.

If you would like to use or distribute our Springer Nature journal content to a wider audience or on a regular basis or in any other manner not expressly permitted by these Terms, please contact Springer Nature at

onlineservice@springernature.com